

ANSSI - Règles et recommandations sur les mécanismes cryptographiques

Tableau de synthèse basé sur le guide ANSSI-PG-083, version 3.00 du 20 mars 2026. Les formulations ci-dessous sont volontairement reformulées pour être lisibles. Les critères chiffrés et identifiants restent ceux du guide ; en cas de doute, le texte officiel fait foi.

Légende : Règle = exigence minimale ; Reco = marge/bonne pratique ; RèglePQ = exigence minimale en contexte post-quantique ; RecoPQ = marge recommandée en contexte post-quantique.

Type	Identifiant officiel	Synthèse compréhensible	Exemples / critères conformes	Non conformes / limites
Général				
Reco	RecoSécuLongTerme	Si un mécanisme doit être utilisé au-delà du 1er janvier 2030, ou s'il existe un risque d'attaque rétroactive, viser une sécurité post-quantique.	Contexte long terme : mécanismes post-quantiques ou hybrides protégeant aussi les données enregistrées aujourd'hui.	Mécanismes classiques seuls exposés au « store now, decrypt later » (ex. échange Diffie-Hellman enregistré). La date 2030 est une estimation révisable.
Reco	RecoMécanismesÉprouvés	Privilégier des mécanismes cryptographiques éprouvés et reconnus par la communauté académique.	Standards largement analysés, documentés et étudiés publiquement.	Mécanismes propriétaires, récents ou peu analysés : recul insuffisant, même si leurs paramètres paraissent robustes.
Cryptographie symétrique				
Règle	RègleTailleCléSym	Une clé symétrique doit avoir une taille effective d'au moins 128 bits.	AES-128, AES-192 et AES-256 satisfont cette exigence de taille.	Triple-DES deux clés : 112 bits effectifs, donc non conforme. Une taille suffisante n'est qu'une condition nécessaire : le mécanisme doit aussi résister aux cryptanalyses.
RecoPQ	RecoPQTailleCléSym	Pour une sécurité post-quantique, utiliser de préférence des clés symétriques d'au moins 192 bits.	AES-192 et AES-256.	AES-128 respecte la règle classique mais pas cette recommandation PQ. Cette recommandation pourrait devenir une règle si les capacités quantiques progressent fortement.
Règle	RègleTailleBlocSym	Une primitive de chiffrement par bloc doit utiliser des blocs d'au moins 128 bits.	AES-128/192/256 : blocs de 128 bits.	Triple-DES : blocs de 64 bits. Limite importante à cause des attaques de type anniversaire lorsque beaucoup de blocs sont traités.
Règle	RèglePrimChiffBloc	Aucune attaque classique contre la primitive ne doit demander moins de 2^{128} opérations de calcul.	AES-128, AES-192 et AES-256.	Triple-DES trois clés : attaque d'environ 2^{112} opérations. La règle ne couvre pas simplement la recherche exhaustive de la clé complète.
RèglePQ	RèglePQPrimChiffBloc	En PQ, aucune attaque quantique ne doit passer sous 2^{80} opérations avec une profondeur inférieure à 2^{48} .	AES-128, AES-192 et AES-256 satisfont la règle PQ selon le guide.	Une primitive vulnérable sous les seuils quantiques indiqués est non conforme. Cette règle complète les exigences classiques.
RecoPQ	RecoPQPrimChiffBloc	En PQ, viser une primitive sans attaque quantique sous 2^{128} opérations et profondeur 2^{64} .	AES-192 et AES-256.	AES-128 satisfait la règle PQ minimale mais pas cette recommandation plus conservatrice.
Règle	RègleModeChiff	Dans le modèle de sécurité pertinent, aucune attaque ne doit être plus efficace que la recherche exhaustive en utilisant significativement moins de $2^{(n/2)}$ blocs sous une même clé.	CBC avec AES et IV aléatoire imprévisible par message ; AES-GCM si les IV ne sont jamais réutilisés sous la même clé.	Réutilisation/prédiction d'IV, trop grand volume sous une même clé, ou mode dont la sécurité tombe avant la borne anniversaire.
Reco	RecoModeChiff	Préférer un mode non déterministe, avec preuve de sécurité adaptée, et ne pas utiliser seul un mode ne fournissant pas l'intégrité.	AES-GCM ; CBC avec IV aléatoire et un mécanisme d'intégrité séparé correctement composé.	CBC/OFB/CFB/CTR seuls : pas d'intégrité. Un IV contrôlable/prévisible ou réutilisé peut annuler les garanties attendues.
Règle	RègleChiffFlot	Un chiffrement par flot dédié ne doit avoir aucune attaque classique sous 2^{128} opérations, avec au plus 2^{64} bits de flot observé.	ChaCha20 est donné conforme.	Tout mécanisme attaquable sous ces seuils. Attention : les règles de cette section ne visent que les chiffrements par flot dédiés, pas CTR/OFB construits sur un chiffrement par bloc.
RèglePQ	RèglePQChiffFlot	Pour une sécurité PQ, le chiffrement par flot doit utiliser un état interne d'au moins 256 bits.	ChaCha20 est donné conforme.	État interne inférieur à 256 bits en contexte PQ.
Reco	RecoChiffFlot	Privilégier un état interne d'au moins 256 bits et compléter le chiffrement par un mécanisme d'intégrité.	ChaCha20 avec authentification/intégrité associée (par ex. construction authentifiée appropriée).	ChaCha20 seul ne respecte pas la recommandation d'intégrité ; le chiffrement par flot est malléable sans protection complémentaire.
Intégrité cryptographique				

Type	Identifiant officiel	Synthèse compréhensible	Exemples / critères conformes	Non conformes / limites
Règle	RègleMAC	La primitive sous-jacente doit être conforme ; aucune attaque classique ne doit passer sous 2^{128} opérations avec moins de 2^{64} requêtes ; tag ≥ 96 bits si sécurité indépendante de la longueur, sinon ≥ 128 bits.	CMAC/AES-128 avec tag 128 ou 96 bits ; GMAC/AES-128 avec tag 128 bits ; HMAC-SHA-256.	CBC-MAC sur messages de taille variable (attaque par extension) ; CBC-MAC retail avec DES/3DES ; tags trop courts selon le mécanisme.
Reco	RecoMAC	Préférer une primitive sous-jacente conforme aux recommandations, un mécanisme avec preuve de sécurité, et des tags d'au moins 128 bits.	HMAC-SHA-256 ; CMAC/GMAC correctement paramétrés avec tag 128 bits.	Tag 96 bits peut rester conforme à la règle dans certains cas mais ne suit pas cette recommandation de marge. Composition chiffrement+MAC à réaliser avec soin.
RèglePQ	RèglePQMAC	En PQ, toute primitive sous-jacente au MAC doit respecter les règles post-quantiques correspondantes.	HMAC-SHA-256 ; CMAC/GMAC avec une primitive sous-jacente satisfaisant les règles PQ.	MAC dont la primitive sous-jacente échoue à une règle PQ.
RecoPQ	RecoPQMAC	En PQ, il est recommandé que la primitive sous-jacente respecte aussi les recommandations PQ associées.	HMAC-SHA-256 est donné conforme aux règles et recommandations ; mécanisme basé sur AES-192/256 selon le contexte.	CMAC/GMAC avec AES-128 : conformes aux règles PQ mais pas à cette recommandation, car AES-128 ne suit pas RecoPQPrimChiffBloc.
Hachage et XOF				
Règle	RègleHachage	Empreinte ≥ 256 bits ; collision classique au niveau générique $\sim 2^{(h/2)}$; préimage $\sim 2^h$.	SHA2-256, SHA3-256, SHA3-384 (selon les critères détaillés du guide).	SHA-1 : taille/résistance collision insuffisantes ; SHA3-224 : empreinte trop courte ; SHAKE-128 fixé à 256 bits comme hash : préimage insuffisante.
Reco	RecoHachage	Éviter une fonction de hachage pour laquelle une attaque partielle sur la construction interne est connue.	SHA2-256, SHA3-256 et SHA3-384 sont cités conformes à cette recommandation.	Toute fonction avec attaque partielle connue, même si cette attaque ne casse pas encore directement la fonction complète.
RecoPQ	RecoPQHachage	Pour une sécurité PQ, privilégier des empreintes d'au moins 384 bits.	SHA3-384 est cité conforme aux règles et recommandations précédentes.	SHA2-256 et SHA3-256 restent conformes aux règles classiques mais pas à cette recommandation PQ. Cas particulier : certaines signatures PQ fondées sur le hachage peuvent avoir des besoins différents explicités par le guide.
Règle	RègleXOF	Pour une sortie h bits : collision classique $\geq \min(2^{(h/2)}, 2^{128})$; préimage $\geq \min(2^h, 2^{128})$.	SHAKE-256 ; SHAKE-128 satisfait les deux règles classiques XOF selon le guide.	Une XOF trop faible en collision ou préimage est non conforme. Une XOF conforme n'est pas automatiquement un hash conforme si on fixe sa taille de sortie.
RèglePQ	RèglePQXOF	En PQ, aucune attaque quantique collision/préimage ne doit franchir les seuils $\min(2^{(h/3)}, 2^{80})$ et $\min(2^{(h/2)}, 2^{80})$, avec profondeur $< 2^{48}$.	SHAKE-256 et SHAKE-128 sont cités conformes aux règles PQ XOF.	Toute XOF dont une attaque quantique passe sous les seuils. Attention à ne pas confondre critères XOF et critères d'une fonction de hachage fixe.
Reco	RecoXOF	Viser une résistance préimage classique $\geq \min(2^h, 2^{256})$ et éviter les XOF avec attaque partielle connue.	SHAKE-256 satisfait les recommandations ; SHAKE-128 satisfait la recommandation relative aux attaques partielles.	SHAKE-128 ne satisfait pas la recommandation de marge préimage RecoXOF.1.
RecoPQ	RecoPQXOF	En PQ, viser des marges supérieures : collision $\geq \min(2^{(h/3)}, 2^{128})$, préimage $\geq \min(2^{(h/2)}, 2^{128})$, profondeur $< 2^{64}$.	SHAKE-256.	SHAKE-128 respecte les règles PQ minimales mais pas les recommandations PQ XOF.
Cryptographie asymétrique				
Règle	RègleSécuAsym	La sécurité classique doit reposer sur un problème mathématique largement éprouvé/reconnu ou sur un mécanisme symétrique conforme.	Factorisation, logarithme discret et courbes elliptiques correctement dimensionnés ; mécanismes utilisant un socle symétrique conforme.	Un mécanisme reposant uniquement sur un problème PQ récent comme (M)LWE/(M)SIS ne satisfait pas à lui seul cette règle classique.
RèglePQ	RèglePQSécuAsym	En PQ, la sécurité doit reposer sur un problème présumé résistant au quantique ou sur un mécanisme symétrique conforme.	(M)LWE/(M)SIS correctement dimensionnés ; mécanismes hybrides classique+PQ.	RSA, Diffie-Hellman ou ECC seuls : cassables en temps polynomial par Shor. Pour la non-régression, le guide recommande souvent l'hybridation avec une composante classique.
Règle	RègleFactorisation	RSA : module ≥ 2048 bits jusqu'à fin 2030, ≥ 3072 bits à partir de 2031 ; exposant secret de taille proche du module ; en chiffrement, exposant public > 65536 et ≤ 256 bits ; facteurs premiers tirés uniformément.	RSA 3072 correctement généré et paramétré.	RSA 1024 est insuffisant ; après 2030, 2048 bits ne suffit plus. Mauvais choix d'exposants ou de nombres premiers également non conforme.
Reco	RecoFactorisation	Préférer dès maintenant des modules ≥ 3072 bits, des exposants publics > 65536 et ≤ 256 bits pour tout usage, et des facteurs premiers de même taille.	RSA 3072 avec facteurs premiers équilibrés et exposant public approprié.	RSA 2048 peut rester conforme à la règle jusqu'à fin 2030 mais ne suit pas cette recommandation de marge.
Règle	RègleLogDiscretGFp	Module premier ≥ 2048 bits jusqu'à fin 2030, ≥ 3072 bits à partir de 2031 ; ordre du sous-groupe multiple d'un premier d'au moins 250 bits.	Paramètres DH/DSA dans GF(p) respectant ces tailles et ordres.	Modules trop courts ou sous-groupes avec petits facteurs. Aucun de ces mécanismes n'apporte de sécurité PQ contre Shor.

Type	Identifiant officiel	Synthèse compréhensible	Exemples / critères conformes	Non conformes / limites
Reco	RecoLogDiscretGFp	Préférer des modules ≥ 3072 bits même avant 2031 et des sous-groupes d'ordre premier.	Sous-groupe d'ordre premier et module 3072 bits ou plus.	2048 bits peut rester conforme à la règle jusqu'en 2030 mais pas à cette recommandation.
Règle	RègleCourbeElliptiqueGFp	Le sous-groupe doit avoir un ordre multiple d'un premier d'au moins 250 bits ; si une courbe particulière réduit la sécurité à un autre problème, appliquer les règles de ce problème.	FRP256v1 ; P-256/P-384/P-521 ; brainpoolP256r1/P384r1/P512r1 sont cités conformes.	Sous-groupes trop faibles ou courbes particulières réduisant la difficulté. ECC sur GF(p) n'est pas PQ face à Shor.
Reco	RecoCourbeElliptiqueGFp	Préférer des sous-groupes dont l'ordre est premier.	Les courbes conformes citées, utilisées avec un sous-groupe d'ordre premier.	Sous-groupe d'ordre composite : peut rester dans certains cas conforme à la règle minimale mais offre moins de garanties ; attention aux courbes « particulières ».
Règle	RègleCourbeElliptiqueGF2n	Ordre du sous-groupe multiple d'un premier ≥ 250 bits ; n doit être premier ; appliquer toute règle supplémentaire si la courbe réduit la sécurité à un problème plus facile.	Courbes B-283, B-409 et B-571 du FIPS 186-5 sont citées conformes.	n composé réduit fortement la difficulté ; ECC binaire n'est pas PQ face à Shor.
Reco	RecoCourbeElliptiqueGF2n	Préférer des sous-groupes dont l'ordre est premier.	Courbes conformes avec sous-groupe d'ordre premier.	Sous-groupe composite : moins de marge ; n composé est explicitement problématique et viole la règle.
RèglePQ	RèglePQRéseauEuclidien	Pour (M)LWE et (M)SIS, les paramètres doivent offrir une complexité d'attaque quantique au moins équivalente à SVP générique en dimension 400.	Jeux de paramètres standardisés dont l'analyse couvre les meilleures attaques connues et atteint ce seuil.	Paramètres maison ou sous-dimensionnés. Le grand nombre de paramètres LWE/SIS rend l'évaluation délicate ; il faut considérer toutes les attaques connues.
RecoPQ	RecoPQRéseauEuclidien	Pour davantage de marge, viser une complexité quantique au moins équivalente à SVP générique en dimension 600 pour (M)LWE/(M)SIS.	Paramètres standards atteignant cette marge supérieure.	Un jeu atteignant seulement la dimension 400 peut satisfaire la règle PQ mais pas cette recommandation.
Reco	RecoConfidentialitéAsym	Pour KEM/chiffrement asymétrique, préférer une preuve de sécurité dans un modèle pertinent ; en hybridation, les deux mécanismes et le mode d'hybridation doivent préserver le modèle de sécurité le plus fort commun.	ECIES-KEM ; RSAES-OAEP correctement paramétré ; Frodo-KEM avec hybridation classique pour satisfaire aussi la sécurité classique.	RSAES PKCS#1 v1.5 avec oracle de padding ; ML-KEM seul ne satisfait pas RègleSécuAsym. Une mauvaise hybridation peut dégrader la sécurité.
Reco	RecoSignature	Préférer des signatures avec preuve de sécurité ; en hybridation, conserver le même modèle et les propriétés additionnelles requises.	RSA-SSA-PSS correctement paramétré ; ECDSA/ECKCDSA sur courbes conformes ; SLH-DSA ; hybridation classique+ML-DSA correctement composée.	ML-DSA seul ne satisfait pas la règle de sécurité classique. Certaines applications exigent plus que la simple résistance à la contrefaçon (SSH, Bitcoin, ACME, DRKey).
Authentification et établissement de clé				
Reco	RecoConfidentialitéPersistante	Viser la PFS : une compromission ultérieure des secrets long terme ne doit pas révéler les sessions passées ; effacer secrets éphémères et clés de session au plus tard en fin de session.	Établissement de clé utilisant de vrais secrets éphémères détruits après usage.	Conserver les secrets temporaires ou utiliser des mécanismes sans PFS. Les primitives conformes ne suffisent pas si le protocole global est vulnérable aux attaques par le milieu.
RecoPQ	RecoPQConfidentialitéPersistante	En contexte PQ, la PFS doit résister même si un adversaire quantique compromet plus tard les secrets long terme.	Hybridation conçue pour que la compromission future de la partie long terme ne permette pas de déchiffrer les sessions enregistrées.	Diffie-Hellman hybridé uniquement avec une clé symétrique pré-partagée : si cette clé est compromise, les anciennes sessions enregistrées deviennent déchiffrables avec des moyens quantiques.
Règle	RègleSecretFaibleEntropie	Si l'authentification repose sur un secret faible (mot de passe, biométrie...), aucune attaque active ou passive ne doit permettre une recherche exhaustive hors-ligne.	Protocoles qui imposent une vérification en ligne contrôlée et empêchent l'attaquant de tester librement des hypothèses hors-ligne.	Stockage/protocole permettant de tester hors-ligne des mots de passe ou secrets biométriques ; un mot de passe alphanumérique de 8 caractères n'offre au mieux qu'environ 47 bits d'entropie.
Génération d'aléa				
Règle	RègleArchiGénAléa	Employer un retraitement algorithmique avec état interne ; sans générateur physique, utiliser une mémoire non volatile ; état interne ≥ 192 bits ; initialisation avec suffisamment d'entropie.	Architecture avec DRBG/retraitement cryptographique, état ≥ 192 bits et graine de qualité ; mémoire persistante si aucune source physique continue.	Générateur physique utilisé brut, simple « lissage », état trop petit ou initialisation de faible entropie.
Reco	RecoArchiGénAléa	Préférer un état interne ≥ 256 bits, une mémoire non volatile et une source d'aléa qui rafraîchit régulièrement l'état.	Architecture DRBG avec état 256 bits ou plus, persistance et réensemencement périodique.	Architecture minimale satisfaisant seulement 192 bits ou sans rafraîchissement : peut respecter la règle mais pas cette recommandation.
Règle	RègleGénPhysAléa	Le générateur physique doit être documenté fonctionnellement et ses sorties brutes ne doivent pas présenter de défauts statistiques significatifs lors des tests.	Générateur documenté, testé sur un échantillon représentatif ; méthodologie AIS31 citée comme présumée conforme.	Source physique non documentée ou présentant des anomalies statistiques. Les tests visés sont d'usine/ponctuels et doivent être réalisés avant retraitement.

Type	Identifiant officiel	Synthèse compréhensible	Exemples / critères conformes	Non conformes / limites
Reco	RecoGénPhysAléa	Justifier par un raisonnement la qualité de l'aléa produit par le générateur physique.	Modèle/argumentation décrivant la source physique, les traitements et la justification de l'entropie ; AIS31 fournit un cadre pertinent.	Se contenter d'assembler des composants « aléatoires » ou de tests statistiques sans justification de conception.
Règle	RègleGénAléaRetraitement	Les primitives du retraitement doivent être conformes ; si l'état est sain, les sorties doivent paraître aléatoires même si les sources tombent en panne ; les sorties ne doivent pas révéler l'état ; une compromission actuelle ne doit pas révéler les sorties passées.	HMAC_DRBG et Hash_DRBG avec SHA-384 ; CTR_DRBG avec AES-256 (NIST SP 800-90Ar1) sont cités conformes.	Retraitement basé sur primitives non conformes, état récupérable depuis les sorties, ou compromission permettant de reconstruire l'historique des sorties.

Source officielle : <https://messervices.cyber.gouv.fr/documents-guides/anssi-guide-mecanismes-crypto-3.00.pdf>